

JPMorgan Chase 2014: GRC Case Study

Student Workbook — five-week simulation

Girish Nair

Getting Started

This workbook breaks the case into nine guided tasks. Complete the tasks in order. Each task builds a skill that is used in the next task. Do not use the instructor answer key while completing the assignment.

How this fits with your team's workflow: this workbook and the task sheets define *what* to produce and why. Your team's shared task tracker (any board or checklist) defines *who* does each part, in what order, and when it is ready for review. Check the tracker for your role and task status; check the task sheet for what your deliverable must contain.

- Use only facts stated in the case unless you clearly label an assumption.
- Write in plain language. Explain technical terms when you use them.
- Every action must have an owner, a deadline and evidence of completion.
- The final submission should tell management what happened, why it happened, what risk remains and what decision is needed.

Recommended duration

Five weeks: two tasks a week in Weeks 1–4, then the capstone (Task 9 and the final team presentation) in Week 5. About 13–15 hours of classroom time plus independent work. The instructor releases each week's two tasks together.

Suggested six-student role model

Student	Role	Primary responsibilities
1	GRC Coordinator	Organizes work, consolidates submissions, manages actions and prepares executive reporting.
2	Asset and Control Analyst	Owns inventory, control scope, MFA and network-control analysis.
3	Risk Analyst	Writes risk statements, scores risks and maintains the risk register.
4	Compliance and Controls Analyst	Maps requirements, identifies evidence and assesses compliance gaps.
5	Incident and Communications Analyst	Builds the timeline, tabletop decisions and stakeholder communication.
6	Internal Auditor / Quality Reviewer	Challenges evidence, scoring, ownership and closure; preserves independence.

For smaller classes

One student can complete the simulation individually, or teams of three can combine roles 1+5, 2+3 and 4+6. For larger classes, create several teams and compare their risk decisions.

Five-week schedule

Week	Tasks	Focus
1	Task 1, Task 2	Case facts, terminology, incident timeline and stakeholders
2	Task 3, Task 4	Asset scope, control gaps and risk statements
3	Task 5, Task 6	Risk scoring, evidence and framework mapping
4	Task 7, Task 8	Corrective actions, exceptions, metrics and escalation
5	Capstone: Task 9 + final presentation	Tabletop, executive report and Risk Committee presentation

Weeks 1–4 each carry two tasks, so the team works on both in parallel. Task 2 builds on Task 1, and so on, so finish the first task of the week before consolidating the second.

How each week flows

Every week follows the same three-stage pattern across two meetings. Learn it once.

Stage 1 — Meeting 1 (whole group, about 20 minutes)

The week's two tasks are released. Confirm who is doing which role for each task, and read the relevant case material together if needed. No deliverable work happens yet.

Stage 2 — Independent work (no waiting)

These four roles can start immediately after Meeting 1. None of them needs another role's output first.

Role	Works on
S2 Asset & Control Analyst	Their part of both tasks, independently from the case facts
S3 Risk Analyst	Their part of both tasks, independently from the case facts
S4 Compliance & Controls Analyst	Their part of both tasks, independently from the case facts
S5 Incident & Communications Analyst	Their part of both tasks, independently from the case facts

Rule: if you are S2, S3, S4 or S5, you never wait on a teammate to start your part of a task.

Stage 3 — Before and at Meeting 2 (sequential)

Role	Step
S1 Coordinator	Consolidates S2–S5's work into one team draft per task. Can't start until they've submitted.
S6 Internal Auditor	Independently reviews each consolidated draft and challenges weak points. Can't start until S1's draft exists.
S1 Coordinator	Submits both approved deliverables for instructor review once S6 signs off.

Rule: S1's consolidation and S6's review are the only steps that must happen in order, and only after S2–S5 are done.

Target pace

One week = two tasks = two meetings. Because each week carries two tasks, get S2–S5's independent pieces in by mid-week so S1 and S6 have time to consolidate and review both before Meeting 2. If a task is still open after Meeting 2, the usual cause is independent work arriving late.

Deliverables vs. working inputs

Each task has one group deliverable, and that is what gets graded. The six S1–S6 contributions are working inputs that feed it; they are not graded separately.

Role assignment sheet

How the team works

Each student owns a distinct role, but the team produces coordinated deliverables. The GRC Coordinator combines the work. The Internal Auditor reviews and challenges the work but should not complete the other students' deliverables.

Student	Assigned role	Primary responsibilities	Individual deliverables
Student 1	GRC Coordinator	Organizes the team, sets deadlines, tracks actions, consolidates submissions and prepares executive reporting.	Project schedule, action tracker, combined submission and executive summary.
Student 2	Asset and Control Analyst	Reviews the asset inventory, defines control scope and analyzes MFA, vulnerability management and network controls.	Asset inventory, control-scope statement and control-gap analysis.
Student 3	Risk Analyst	Writes risk statements, scores risks, maintains the risk register and recommends priorities.	Risk statements, scored risk register and priority rationale.
Student 4	Compliance and Controls Analyst	Maps gaps to NIST CSF and financial-sector expectations, identifies evidence	Framework mapping, evidence-request list and compliance

Student	Assigned role	Primary responsibilities	Individual deliverables
		and assesses compliance.	conclusion.
Student 5	Incident and Communications Analyst	Builds the incident timeline, identifies stakeholders, records tabletop decisions and prepares communications.	Timeline, stakeholder map, decision log and communication matrix.
Student 6	Internal Auditor / Quality Reviewer	Independently challenges evidence, scoring, ownership and closure. Confirms whether deliverables are complete and defensible.	Quality checklist, challenge notes, validation comments and closure recommendation.

Individual Questions Every Student Must Answer

- What is my role in this simulation?
- What decisions can I make or recommend?
- What information do I need from the other roles?
- What deliverables do I own?
- Who must review or approve my work?
- What could go wrong if my responsibility is unclear?

Team Working Rules

- Use facts from the case and clearly label assumptions.
- Do not change another student's conclusion without discussing the evidence.
- Record unresolved disagreements and ask the Internal Auditor to challenge them.
- Every action must have an owner, target date and expected evidence.
- The final team submission must be internally consistent.

Instructor Assignment Table

Complete this table before releasing Task 1. Each student should retain the same role throughout the simulation unless the instructor intentionally rotates roles.

Student name	Assigned role	Date assigned
	GRC Coordinator	
	Asset and Control Analyst	
	Risk Analyst	
	Compliance and Controls Analyst	
	Incident and Communications Analyst	
	Internal Auditor / Quality Reviewer	

Beginner Glossary

Term	Plain-language meaning
Asset	Anything the organization needs to protect, such as a server, application, database, user account or network device.
Server	A computer that provides a service, hosts an application or stores data for other computers.
Microsite	A small website created for a specific campaign, event or purpose.
MFA / 2FA	Multi-factor or two-factor authentication. A user must provide more than a password, such as a phone approval or security token.
Vulnerability	A weakness that could be used to gain unauthorized access or cause harm.
Control	A policy, process or technology used to reduce risk.
Control exception	A known situation where a required control is not fully applied.
Compensating control	A temporary or alternative safeguard used while the required control is unavailable.
Asset inventory	The official list of systems, applications, devices and owners.
Lateral movement	When an attacker moves from the first compromised system to other internal systems.
Network segmentation	Separating systems into zones so that a compromise in one area does not automatically reach another.
Risk	The possibility that an event will affect objectives. A useful risk statement includes cause, event and impact.
Likelihood	How probable the event is.
Impact	How serious the consequences would be.
Inherent risk	Risk before considering controls.
Residual risk	Risk remaining after controls and corrective actions.
Risk owner	The person accountable for deciding and overseeing how a risk is handled.
KPI	Key Performance Indicator. Measures whether a process is performing as intended.
KRI	Key Risk Indicator. Warns that risk exposure may be increasing.
SIEM	A security monitoring system that collects logs and alerts analysts to unusual activity.

Task 1: Understand the Case and Learn the Basic Terms

Suggested time: 60-75 minutes · **Primary lead:** GRC Coordinator

Required outputs

Case fact sheet; glossary check; 150-word breach summary; five questions for the instructor.

Why this task matters

Students first separate verified facts from assumptions and learn the technical words needed for later tasks.

Learning objectives

- Explain the breach in plain language.
- Identify the organization, affected people, exposed data, entry point and root cause.
- Distinguish a fact stated in the case from an assumption or unanswered question.

Action items

1. Read the executive summary and incident timeline.
2. Review the beginner glossary before answering questions.
3. Complete the Who, What, When, Where, How and Impact fact sheet.
4. Write a 150-word summary that a non-technical manager could understand.
5. List five questions that would require additional evidence or investigation.

Questions to answer

- Who was affected by the breach?
- What information was accessed?
- What information was not confirmed stolen?
- What system was used as the initial entry point?
- What required security control was missing from that system?
- Why is this described as a governance failure rather than only a technology failure?
- What is the difference between a verified fact and an assumption?

Case Fact Sheet

Question	Student response	Case evidence / page

Plain-English Summary

Write a 150-word summary for a non-technical manager

Investigation Questions

No.	Question requiring more evidence	Why it matters

Required deliverables

- Completed case fact sheet.
- 150-word plain-English summary.
- Five investigation questions.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 2: Build the Incident Timeline and Identify Stakeholders

Suggested time: 75 minutes · **Primary lead:** Incident and Communications Analyst

Required outputs

Incident timeline; stakeholder map; responsibility and information-needs table.

Why this task matters

A timeline shows how the incident developed. A stakeholder map shows who must act, approve, investigate or receive updates.

Learning objectives

- Place key events in chronological order.
- Identify internal and external stakeholders.
- Explain what information each stakeholder needs and why.

Action items

1. Create a timeline from reconnaissance through public disclosure and later prosecution.
2. Label each event as attack activity, detection, response, disclosure or legal follow-up.
3. List at least eight stakeholders.
4. For each stakeholder, identify their role, decision authority and information needs.
5. Identify two points where earlier action could have reduced the impact.

Questions to answer

- When did the compromise begin, and when was it detected?
- How long were the attackers present before detection?
- What happened after suspicious activity was identified?
- Which stakeholders should have known about the unprotected server before the incident?
- Which stakeholders needed immediate notification after detection?

Incident Timeline Template

Date / period	Event	Category	Why it matters

Stakeholder Map Template

Stakeholder	Role / decision	Information needed	When informed

Required deliverables

- Seven-event minimum incident timeline.
- Stakeholder map with at least eight stakeholders.
- Two missed-intervention points.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 3: Create an Asset Inventory and Define Control Scope

Suggested time: 90 minutes · **Primary lead:** Asset and Control Analyst

Required outputs
Simplified asset inventory; ownership gaps; control-scope statement; inventory completeness checks.

Why this task matters

Controls cannot protect assets that are missing from the official inventory or outside the stated scope.

Learning objectives

- Identify systems, data, owners and connections.
- Explain why internet-facing and business-managed systems remain in security scope.
- Propose simple checks that confirm the inventory is complete.

Action items

1. Create an inventory of at least six assets mentioned or implied in the case.
2. Record business owner, technical owner, data handled, internet exposure, criticality and applicable controls.
3. Mark the asset that was omitted from the MFA program.
4. Write a control-scope statement for MFA and vulnerability management.
5. Propose four inventory completeness checks.

Questions to answer

- Why was the Corporate Challenge server easy to miss?
- Who should be accountable for registering a new microsite?
- Does a low-business-criticality website still require strong security controls?
- How can the organization test whether the inventory is complete?

Asset Inventory Template

Asset	Business owner	Technical owner	Data	Internet?	Controls

Asset	Business owner	Technical owner	Data	Internet?	Controls

Control Scope Statements

Control	Systems / accounts in scope	Permitted exceptions	Proof of coverage

Inventory Completeness Tests

Test	Source compared	Frequency	Owner	Action on mismatch

Required deliverables

- Asset inventory with at least six rows.
- MFA and vulnerability-management scope statement.
- Four inventory completeness tests.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 4: Identify Risks and Write Clear Risk Statements

Suggested time: 90 minutes · **Primary lead:** Risk Analyst

Required outputs

Six cause-event-impact risk statements; control-gap table; risk owners.

Why this task matters

A GRC professional must convert technical facts into business risks that management can understand and own.

Learning objectives

- Use the cause-event-impact structure.
- Separate a control weakness from the business risk created by that weakness.
- Assign a logical risk owner.

Action items

1. Identify at least six risks from the case.
2. Write each risk using: Because of [cause], there is a possibility that [event], resulting in [impact].
3. Identify the failed or missing control.
4. Assign a business risk owner and a supporting control owner.
5. State the affected confidentiality, integrity or availability objective.

Questions to answer

- Is 'no MFA' a risk or a control gap?
- What business impacts could result from an incomplete asset inventory?
- Why should business owners participate in cybersecurity risk ownership?

Risk statement formula

Because of [cause/control weakness], there is a possibility that [risk event], resulting in [business impact].

Risk Identification Template

ID	Cause	Risk event	Business impact	Control gap	Risk owner	CIA

Required deliverables

- Six complete risk statements.
- Control-gap and ownership table.
- CIA classification for each risk.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 5: Assess and Prioritize the Risks

Suggested time: 90 minutes · **Primary lead:** Risk Analyst with Internal Auditor review

Required outputs

Completed risk register (likelihood x impact, score and rating); priority list; scoring rationale; audit challenge notes.

Why this task matters

Risk scoring helps management decide which problems require immediate action, but scores must be supported by evidence and consistent criteria.

Learning objectives

- Apply simple likelihood and impact scales.
- Calculate inherent risk scores.
- Prioritize risks and explain the reasoning.
- Challenge unsupported or inconsistent scoring.

Action items

1. Use the provided 1-to-5 likelihood and impact scales.
2. Score the six risks from Task 4 before new corrective actions.
3. Calculate score = likelihood x impact.
4. Classify 1-4 Low, 5-9 Moderate, 10-16 High and 17-25 Critical.
5. Rank the top three risks.
6. Have the Internal Auditor challenge at least two scores.

Questions to answer

- Why should R2 and R4 be treated as high or critical?
- Can two risks have the same score but different urgency?
- What evidence would change a likelihood or impact score?

Likelihood Scale

Rating	Description	Beginner-friendly guide
1	Rare	No known occurrence and strong preventive controls.
2	Unlikely	Possible, but limited evidence and good controls.
3	Possible	Could occur; examples exist in the industry.
4	Likely	Has occurred internally or controls are materially weak.
5	Almost Certain	Is occurring, recently occurred or is expected repeatedly.

Impact Scale

Rating	Description	Beginner-friendly guide
1	Insignificant	Little disruption; no sensitive data or regulatory effect.
2	Minor	Limited users or short disruption; easily corrected.
3	Moderate	Noticeable business impact, internal escalation or limited sensitive data.
4	Major	Large customer impact, significant operational disruption or likely regulatory scrutiny.
5	Critical	Very large data exposure, severe financial/reputational harm or threat to major services.

Scoring formula

Inherent risk score = Likelihood x Impact. Use the case evidence and document the reason for every score.

Risk Register Template

ID	Risk	L	I	Score	Rating	Rationale

Independent Scoring Challenge

Risk ID	Auditor challenge	Evidence requested	Final decision

Required deliverables

- Risk register with likelihood, impact, score and rating.
- Top-three priority statement.
- Two documented scoring challenges and final decisions.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 6: Map the Gaps to GRC Frameworks and Requirements

Suggested time: 90 minutes · **Primary lead:** Compliance and Controls Analyst

Required outputs

NIST CSF gap map; simplified regulatory mapping; evidence list; compliance conclusion.

Why this task matters

Framework mapping connects a real event to expected governance and control practices. Beginners should focus on the purpose of each requirement rather than memorizing control numbers.

Learning objectives

- Use NIST CSF functions to organize gaps.
- Explain the relevance of FFIEC, GLBA, OCC and SEC requirements in plain English.
- Identify evidence needed to prove control operation.

Action items

1. Map case facts to Identify, Protect, Detect, Respond and Recover.
2. Mark each function Effective, Adequate, Partial or Gap and explain why.
3. Map at least four regulatory or standards requirements to the case.
4. List evidence an auditor would request.
5. Write a one-paragraph compliance conclusion.

Questions to answer

- Which NIST CSF functions were weakest?
- Which functions worked relatively well after detection?
- Why does a framework mapping require evidence rather than only a written policy?
- How would current SEC disclosure expectations differ from 2014 practice?

NIST CSF Assessment Template

Function	Rating	Case facts	Gap / strength	Evidence needed

Function	Rating	Case facts	Gap / strength	Evidence needed

Regulatory Mapping Template

Requirement	Plain-language expectation	Case implication	Evidence

Required deliverables

- Completed NIST CSF assessment.
- Four-requirement regulatory mapping.
- Evidence request list.
- Compliance conclusion.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 7: Design the Corrective Action and Exception Management Plan

Suggested time: 105 minutes · **Primary lead:** GRC Coordinator and Control Owners

Required outputs

30-60-90 day corrective-action plan; exception register; RACI; residual-risk decisions.

Why this task matters

A finding is not resolved until an owner completes an action, evidence is validated and remaining risk is formally accepted or closed.

Learning objectives

- Select appropriate risk treatment actions.
- Create specific actions with owners and dates.
- Design a closed-loop exception process.
- Separate management implementation from independent validation.

Action items

1. Choose mitigate, avoid, transfer or accept for each priority risk.
2. Create a 30-60-90 day plan.
3. Complete a sample exception register for the missing MFA control.
4. Build a RACI for asset registration, exception approval, remediation and validation.
5. Estimate residual risk after the plan and state who approves it.

Questions to answer

- What makes a corrective action measurable?
- What information must every exception contain?
- Why should an externally accessible exception require higher approval?
- Who should validate closure?

Corrective Action Plan

Timeframe	Action	Owner	Due date	Success evidence	Status

Exception Register Entry

Field	Student response

RACI Template

Activity	Responsible	Accountable	Consulted	Informed

Activity	Responsible	Accountable	Consulted	Informed

Required deliverables

- Corrective-action plan with actions, owners, dates and evidence.
- Completed exception-register entry.
- RACI matrix.
- Residual-risk statement.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 8: Create KRIs, KPIs and an Ongoing Monitoring Dashboard

Suggested time: 90 minutes · **Primary lead:** GRC Reporting Analyst

Required outputs

KPI/KRI catalog; dashboard; thresholds; reporting and escalation schedule.

Why this task matters

Management needs measures that reveal both whether controls are working and whether risk is increasing.

Learning objectives

- Distinguish KPIs from KRIs.
- Create measurable coverage and exception indicators.
- Define thresholds and escalation actions.

Action items

1. Create at least four KPIs and four KRIs.
2. Define calculation, target, threshold, owner and reporting frequency.
3. Build a one-page red-amber-green dashboard.
4. Define escalation rules for overdue critical exceptions.
5. Identify evidence sources for each metric.

Questions to answer

- Why is 'number of security tools' a weak measure of control effectiveness?
- Which metric best tests asset-inventory completeness?
- Which metric warns that exception risk is increasing?
- What should happen when a critical threshold is breached?

KPI and KRI Catalog

Type	Metric	Calculation	Target	Threshold	Owner	Frequency

Type	Metric	Calculation	Target	Threshold	Owner	Frequency

Dashboard

Measure	RAG status	Current result	Required action

Required deliverables

- Eight-metric catalog.
- One-page dashboard (red-amber-green format).
- Escalation and reporting schedule.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Task 9: Conduct the Incident Tabletop and Present to Executives

Suggested time: 120 minutes · **Primary lead:** Incident Lead with all students participating

Required outputs

Tabletop decision log; communication matrix; one-page executive report; five-minute presentation.

Why this task matters

The final task combines governance, risk, controls, incident response and communication in a realistic management exercise.

Learning objectives

- Make time-sensitive decisions using incomplete information.
- Communicate technical facts as business risk.
- Recommend immediate and long-term actions to executives.
- Demonstrate an evidence-based GRC conclusion.

Action items

1. Respond to four instructor injects.
2. Record decision, owner, deadline, rationale and evidence for each action.
3. Create a communication matrix for executives, regulators, law enforcement, employees and customers.
4. Write a one-page executive report using Situation, Impact, Root Cause, Actions and Decisions Needed.
5. Deliver a five-minute Risk Committee presentation.

Questions to answer

- What should be done in the first four hours after suspicious activity is confirmed?
- When should business operations be interrupted to contain risk?
- What facts must be verified before public communication?
- What decisions require executive or Risk Committee approval?
- What is the single most important governance lesson?

Tabletop Decision Log

Inject / new fact	Decision	Owner	Deadline	Rationale	Evidence

Communication Matrix

Audience	Information	Timing	Owner	Approval

Executive Report Template

Section	Required content

Required deliverables

- Completed tabletop decision log.
- Communication matrix.
- One-page executive report.
- Five-minute presentation and responses to questions.

Self-check before submission

- ☐ I used facts from the case and labeled assumptions.
- ☐ I explained technical terms in plain English.
- ☐ My actions have owners, dates and evidence.
- ☐ My conclusions are consistent with earlier tasks.

Capstone: Final Team Presentation

The capstone has two parts:

1. **Task 9 — Incident tabletop and executive briefing.** Run the tabletop, keep a decision log, build the communication matrix, and write a one-page executive report.
2. **Final team presentation (this brief).** Present the whole case, Tasks 1–9, as one governance story to a mock Risk Committee.

The tasks are organized for grading. This presentation reorganizes the same work by presenter, in speaking order. Each task belongs to exactly one presenter, so no two people cover the same ground, and each section ends with a spoken bridge into the next.

Speaking order and ownership

Order	Presenter	Task(s)	Content
1	S1 — GRC Coordinator	T1	Case framing, executive audit summary, overall opinion. Opens the session.
2	S2 — Asset & Control Analyst	T2, T3	Incident timeline and stakeholders (T2); asset inventory and control-scope definition, including the MFA and vulnerability-management scope statements (T3).
3	S3 — Risk Analyst	T4, T5	All six risk statements as one set (T4); likelihood × impact scoring, top-3 prioritization, and the auditor-challenge outcomes (T5).
4	S4 — Compliance & Controls Analyst	T6, T7 (remediation)	Framework mapping to NIST CSF, FFIEC, GLBA and OCC (T6); the remediation half of T7: 30-60-90 day actions, exception register, RACI.
5	S5 — Incident & Communications Analyst	T7 (incident/comms), T8	The incident and communications half of T7: escalation ladder and notification protocol; the KRI/KPI monitoring dashboard (T8).
6	Capstone lead (any team member)	T9	Tabletop decision log, communication matrix, one-page executive report, and a 5-minute Risk Committee briefing.
7	S6 — Internal Auditor	Cross-task	Closes with combined audit findings: conformance by task, key challenge-log outcomes, and the final scorecard. Findings only, not task content.

With fewer than six students, combine roles but keep the Internal Auditor separate from the work they review.

Spoken bridges between sections

- **S1 → S2:** "With the incident framed, here's who should have caught it and what they'd have needed to see."
- **S2 → S3:** "Those control and inventory gaps translate directly into scored risk. Here's the register."
- **S3 → S4:** "Once risk is scored, the next question is what it means against the frameworks we're actually held to."
- **S4 → S5:** "None of this stays fixed without ongoing monitoring and a clear escalation path when it breaks."
- **S5 → Capstone lead:** "So how would this actually play out in the room? Here's the tabletop."
- **Capstone lead → Auditor:** "That's what the team built. Now, independently, here's whether it holds up."

Why the presentation is structured this way

T4 stays whole under the Risk Analyst. Splitting the six risk statements across two presenters is exactly the kind of overlap that breaks a live handoff. S3 owns the full risk narrative and credits other roles' input verbally rather than dividing slides.

T6 goes to the Compliance & Controls Analyst. Framework mapping is a direct extension of that role's mandate. T9 needs more original synthesis, so it suits whoever is leading the capstone.

The Internal Auditor presents last and separately. The auditor's role is independent challenge, not narration. Presenting combined findings after all task content keeps the challenge visibly independent of the claims being challenged.

Timing

Plan for 35–45 minutes: about 5 minutes per presenter, the 5-minute Risk Committee briefing inside the T9 slot, and 5–10 minutes for committee questions.

How it's graded

The presentation is scored with the final grading rubric. Executive communication counts most here: clear business language, concise recommendations, and an explicit statement of the decision the committee needs to make.

Final Grading Rubric

Assessment area	Weight	What good work looks like
Understanding of case facts	15%	Accurate facts; assumptions clearly labeled.
Risk identification and scoring	20%	Clear cause-event-impact statements; defensible ratings.
Control and framework analysis	15%	Relevant mappings supported by evidence.
Corrective actions and ownership	20%	Specific, time-bound, measurable and assigned.
Monitoring and reporting	10%	Useful KPIs/KRIs with thresholds and escalation.
Executive communication	10%	Clear business language, concise recommendations and decisions needed.
Teamwork / individual contribution	10%	Role completed, dependencies managed and quality review performed.

Academic integrity

The instructor answer key contains model responses, not the only acceptable responses. Students may reach different conclusions when they explain their assumptions and support decisions with case evidence.